TEK1314 KEAMANAN SIBER | KELOMPOK 12 B

Skenario 10: IoT Protocol Guardian

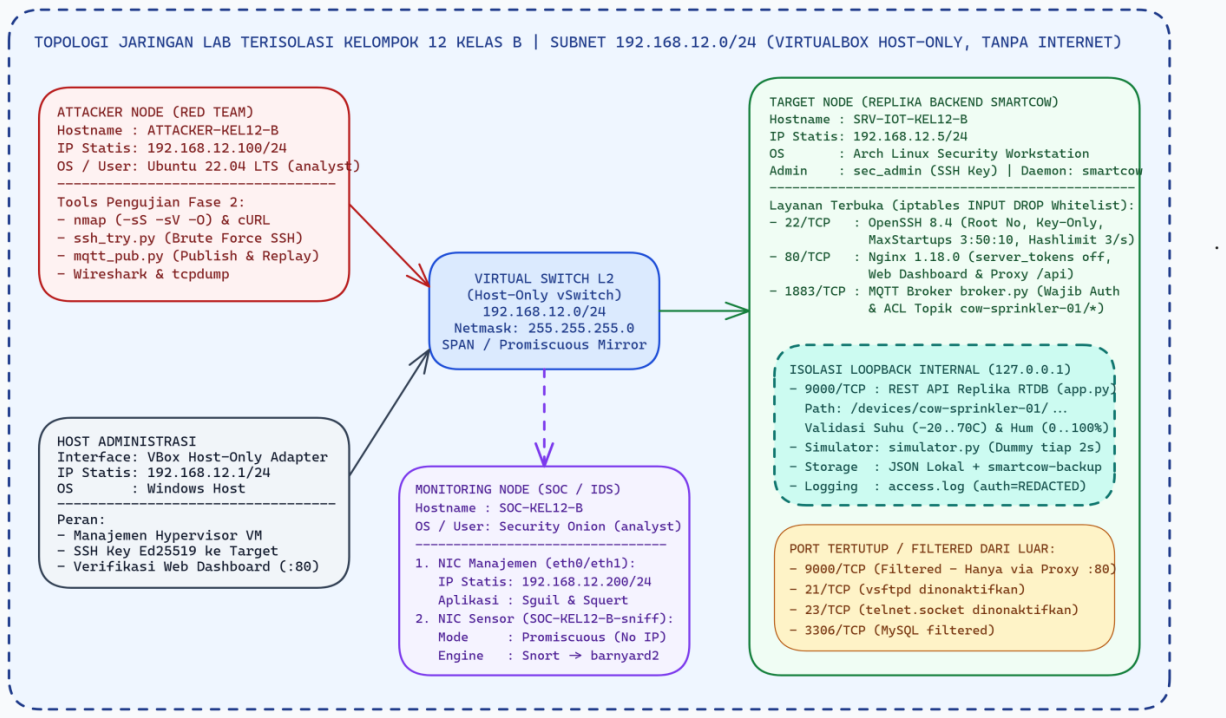
Pengujian & Hardening Infrastruktur Backend Sistem SmartCow Sprinkler pada Lab Virtual Terisolasi

ANGGOTA KELOMPOK 12 KELAS B (SV IPB):

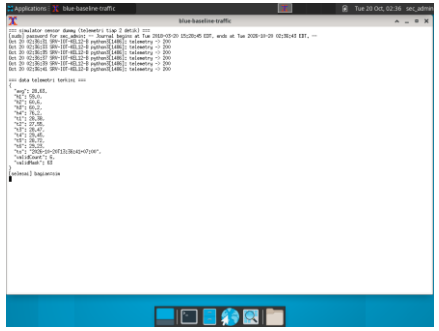
Thevan Erlangga (J0404241073)
Lead & Purple Team Coordinator
Muhamad Akhdan Ramadhan (J0404241102)
Red Team (Offensive Security & Exploit)
Fachri Abyasa Tarid (J0404241136)
Blue Team (Defensive Hardening & IDS)

LINGKUNGAN UJI: SUBNET 192.168.12.0/24

Mode VirtualBox Host-Only Statis tanpa akses internet. Seluruh pengujian memakai 100% data telemetri sintetis (dummy) tanpa menyentuh server produksi mitra.



Gambar 1.1: Arsitektur Simulasi Lab Terisolasi Kelompok 12 Kelas B (192.168.12.0/24)



Bukti Baseline Telemetri (simulator.py)

Ringkasan Progres Checkpoint

9 Kontrol Hardening (100% Done): Tersebar merata di Kategori A, B, dan C.
4 Skenario Uji Red Team: RT-01 s.d. RT-04 terverifikasi pada siklus Purple Team.
Repositori GitHub: `SwipeLz/TEK1314-2026-Kel-12-Kelas-B`

Konteks Proyek IoT SmartCow & Identifikasi Celah Asli

01 | KONTEKS SISTEM

Arsitektur perangkat keras/cloud sistem sprinkler kandang sapi perah dan 3 temuan kerentanan pada kode sumber firmware

1. Perangkat Sensor Kandang

Enam sensor suhu DS18B20 (bus OneWire) dan empat sensor kelembapan DHT22 terpasang pada dua unit mikrokontroler ESP32 (Kiri & Kanan) untuk memantau kondisi termal kandang sapi perah.

2. Agregasi & Cloud RTDB

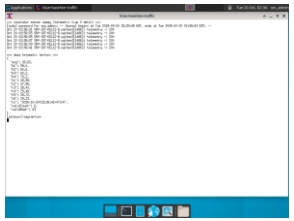
ESP32 Kanan menghitung rata-rata suhu serta indeks stres panas (THI = Temperature-Humidity Index), lalu mengirim data ke Firebase Realtime Database via HTTPS REST tiap 2 detik.

3. Dashboard Web Peternak

Aplikasi web statis (HTML/CSS/JS) pada Firebase Hosting digunakan peternak memantau suhu/kelembapan secara real-time dan mengatur ambang penyalaan semprotan air.

4. Aktuator Solenoid 220V

Modul Solid State Relay (SSR) pada pin GPIO23 mengendalikan katup solenoid air 220V dengan logika histeresis, batas durasi semprot maksimum, dan jeda pendinginan (cooldown).



Bukti Replikasi Struktur Telemetri SmartCow (t1..t6, h1..h4, avg, thi) pada Simulator Lab

Celah 01: Hardcoded Database Secret

Berkas firmware esp32/src/main.cpp menyematkan parameter ?auth=<secret> secara eksplisit dalam kode sumber. Jika firmware bocor, penyerang memperoleh hak tulis penuh ke database tanpa melewati aturan peran dashboard.

Celah 02: Validasi TLS Dinonaktifkan

Komunikasi HTTPS dari mikrokontroler memanggil fungsi setInsecure() yang mematikan verifikasi sertifikat Root CA server, sehingga jalur telemetri rentan terhadap penyadapan dan serangan Man-in-the-Middle (MitM).

Celah 03: ESP-NOW Tanpa Enkripsi & Secret Lama

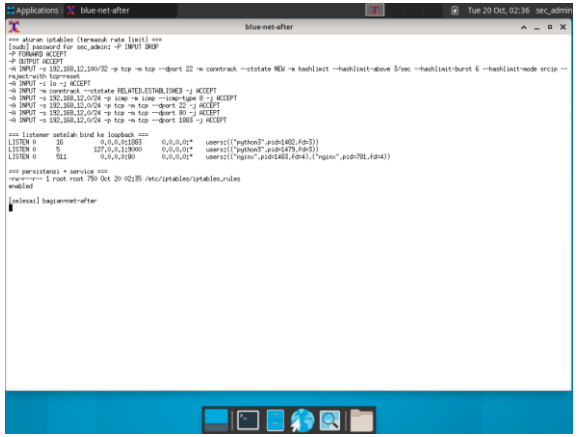
Transmisi nirkabel 2,4 GHz antar-ESP32 menggunakan protokol ESP-NOW tanpa enkripsi payload (rawan injeksi paket lokal), serta berkas js/firebase-config.js pernah terekspos di dokumentasi internal.

Deklarasi Tech Stack: Sistem Produksi vs Replika Lab

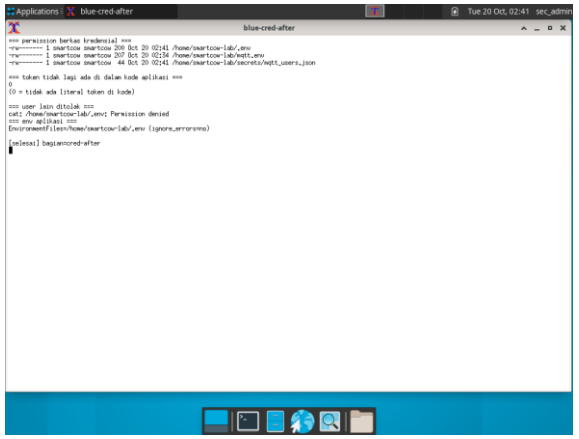
02 | TECH STACK

Pemetaan presisi komponen cloud Google Firebase ke replika mandiri berbasis Arch Linux dan Python 3.9 di laboratorium offline

Komponen Arsitektur	Teknologi Sistem Produksi (Asli)	Replika pada Target Node Lab (.5)
1. OS Layanan Backend	Serverless Google Firebase (tanpa manajemen OS host)	Arch Linux Security Workstation (SRV-IOT-KEL12-B), layanan systemd user non-root smartcow
2. Database & Storage	Firebase RTDB pada path devices/cow-sprinkler-01/...	Penyimpanan JSON lokal dengan endpoint REST bergaya RTDB di 127.0.0.1:9000 (app.py)
3. Protokol Telemetri	HTTPS REST + Database Secret, ESP32 kirim tiap 2 detik	HTTP REST + Token Bearer, skrip simulator.py kirim data dummy tiap 2 detik
4. Dashboard & Proxy	Firebase Hosting (aplikasi web statis HTML/CSS/JS)	Nginx 1.18.0 port 80 menyajikan dashboard & meneruskan rute /api ke loopback :9000
5. Auth & Broker IoT	Firebase Auth, RTDB Rules (/access/<uid>), opsi MQTT	Token Bearer API + daemon broker MQTT mandiri (broker.py) port 1883 ber-auth & ACL topik
6. Logging & IDS	Firebase node events & status (belum ada IDS jaringan)	systemd-journald, logs/access.log, logs/broker.log, & Security Onion Snort IDS (.200)



Bukti Listener Replika (ss -lntp: Nginx :80, MQTT :1883, API 127.0.0.1:9000)



Bukti Isolasi Berkas Kredensial (.env & mqtt_users.json Mode 600 User smartcow)

Topologi Jaringan & Skema Pengalamatan IP (192.168.12.0/24)

Arsitektur simulasi tiga mesin virtual dan satu host administrasi pada jaringan VirtualBox Host-Only terisolasi

1. Attacker Node — 192.168.12.100/24

Hostname: ATTACKER-KEL12-B | OS: Ubuntu 22.04 LTS (user: analyst)
Perangkat Uji: nmap, Wireshark, tcpdump, cURL, skrip ssh_try.py (brute-force SSH), dan mqtt_pub.py (injeksi & replay MQTT).

2. Target Node (Replika) — 192.168.12.5/24

Hostname: SRV-IOT-KEL12-B | OS: Arch Linux (admin: sec_admin)
Layanan Aktif: OpenSSH (22/TCP), Nginx Reverse Proxy (80/TCP), Broker MQTT (1883/TCP), serta REST API internal di loopback (127.0.0.1:9000).

3. Monitoring Node (SOC) — 192.168.12.200/24

Hostname: SOC-KEL12-B | OS: Security Onion (user: analyst)
Dua Antarmuka: NIC Manajemen (192.168.12.200) untuk konsol Sguil/Squert, dan NIC Sensor (SOC-KEL12-B-sniff) mode promiscuous tanpa IP (Snort IDS).

4. Host Administrasi — 192.168.12.1/24

Interface: Windows VirtualBox Host-Only Adapter (Netmask 255.255.255.0)
Peran: Manajemen hypervisor 3 VM, akses administratif SSH Key Ed25519 ke Target Node, dan pengujian akses dashboard web port 80.

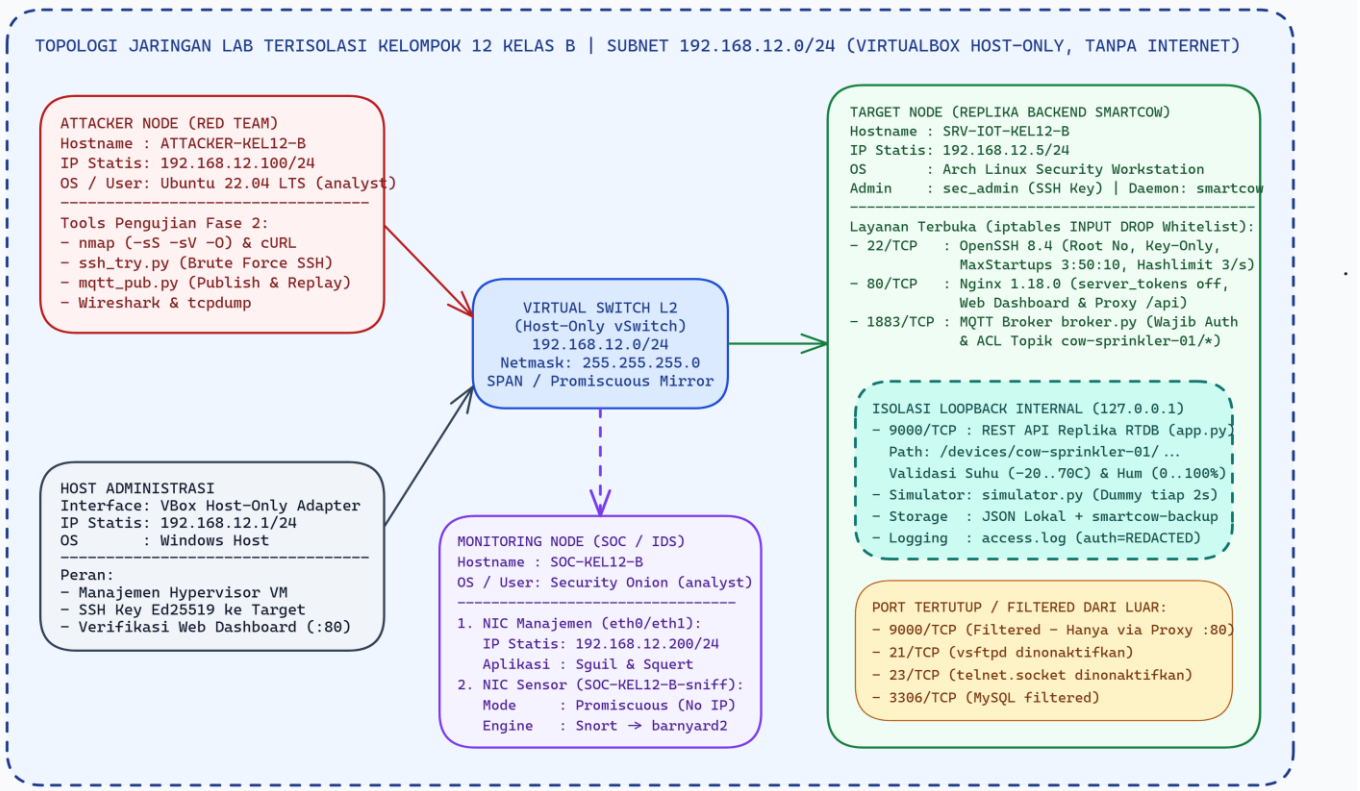


Diagram Topologi Jaringan Lab Terisolasi 192.168.12.0/24 & Alokasi Port Layanan (Mode Host-Only)

Progres Hardening Blue Team: 9 Kontrol Keamanan (100% Done)

Implementasi pertahanan berlapis (defense-in-depth) pada Target Node melampaui standar minimum 8 kontrol Panduan PBL

Kategori A: Access & Authentication (3 Kontrol — DONE)

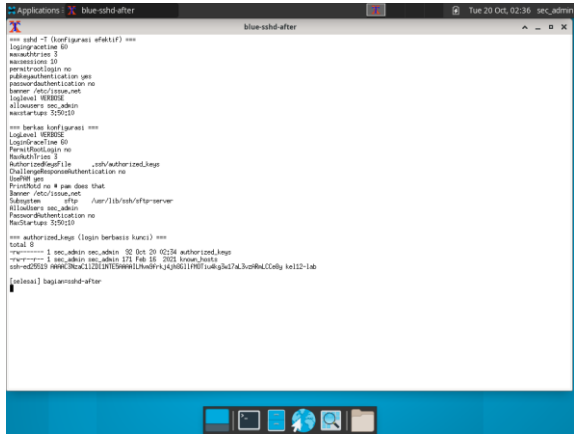
- A1 (Tolak Login Root): Direktif PermitRootLogin no dan AllowUsers sec_admin pada sshd_config menolak seluruh percobaan login langsung ke akun root.
- A2 (Autentikasi Kunci SSH): Pasangan kunci Ed25519 dipasang pada authorized_keys (mode 600) dan PasswordAuthentication no diaktifkan.
- A3 (Batas Sesi & Rate Limit): Konfigurasi MaxStartups 3:50:10 pada sshd dan modul iptables hashlimit (maks 3 koneksi/detik, burst 6, TCP RST).

Kategori B: Service & Attack Surface (3 Kontrol — DONE)

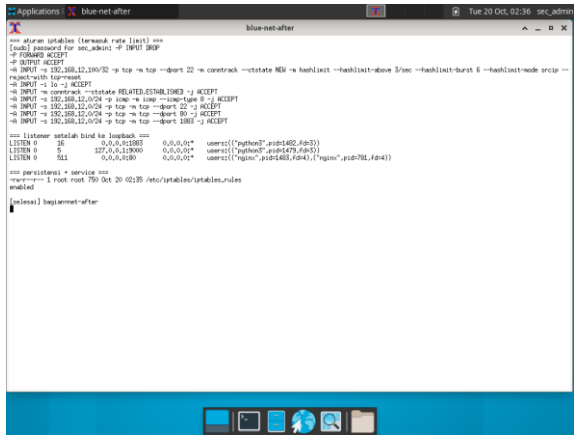
- B1 (Firewall Whitelist Persisten): Kebijakan default INPUT DROP; hanya mengizinkan loopback, ICMP lab, dan TCP port 22, 80, 1883 via /etc/iptables/iptables.rules.
- B2 (Isolasi Loopback API): Mengubah SMARTCOW_BIND dari 0.0.0.0:9000 ke 127.0.0.1:9000 sehingga API hanya dapat diakses melalui reverse proxy Nginx.
- B3 (Sembunyikan Banner Versi): Direktif server_tokens off pada /etc/nginx/nginx.conf mengubah header respon dari nginx/1.18.0 menjadi Server: nginx.

Kategori C: Data & Application Security (3 Kontrol — DONE)

- C1 (Validasi Input & ACL MQTT): Membatasi suhu (-20..70 C), kelembapan (0..100%), THI (0..130), wajib auth MQTT, dan mencabut izin tulis sensor di topik control.
- C2 (Proteksi & Rotasi Kredensial): Menghapus literal token dari kode sumber ke file .env berizin 600 (user smartcow) dan merotasi token via openssl rand -hex 16.
- C3 (Sanitasi Log & Backup): Mencatat aktivitas ke access.log (dengan sensor auth=REDACTED) & broker.log, disertai skrip /usr/local/bin/smartcow-backup.



Bukti Kontrol A1-A3: Konfigurasi sshd -T & Kunci Publik Ed25519



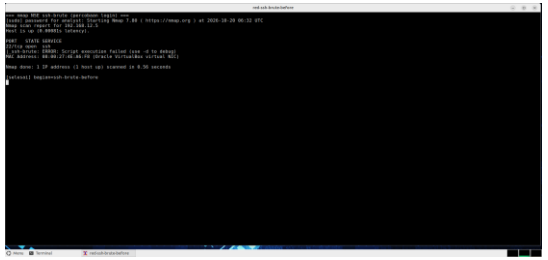
Bukti Kontrol A3, B1 & B2: Aturan iptables INPUT DROP & Loopback :9000

Matriks Verifikasi Teknis: Sebelum vs Sesudah Hardening

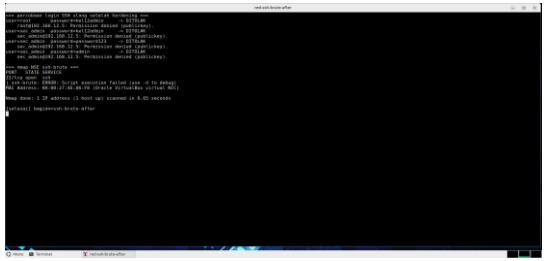
05 | VERIFIKASI

Rekapitulasi hasil pengujian verifikasi pada 9 kontrol pengamanan Target Node beserta bukti tangkapan layar terminal

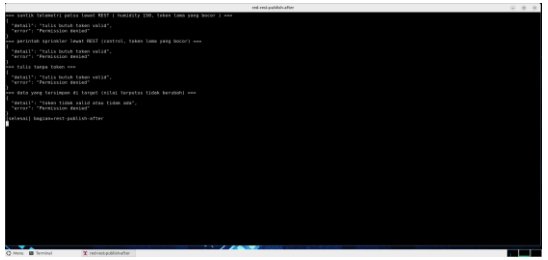
ID	Kategori & Fokus	Kondisi Sebelum Hardening (Vulnerable)	Kondisi Sesudah Hardening (Hardened)	Status
A1	**Access: Login Root**	PermitRootLogin without-password, batas default longgar	PermitRootLogin no & AllowUsers sec_admin; login root ditolak	DONE
A2	**Access: Kunci SSH**	PasswordAuthentication yes; login kata sandi sederhana berhasil	PasswordAuthentication no & wajib kunci Ed25519 (mode 600)	DONE
A3	**Access: Rate Limit**	MaxStartups 10:30:100; tanpa pembatasan laju paket SSH	MaxStartups 3:50:10 & iptables hashlimit 3/detik (TCP RST)	DONE
B1	**Surface: Firewall**	Tabel iptables kosong (default ACCEPT) setelah VM direstart	Default INPUT DROP, whitelist 22, 80, 1883 persisten saat boot	DONE
B2	**Surface: Isolasi API**	Listener API terikat pada 0.0.0.0:9000 (terbuka ke jaringan luar)	Bind eksklusif 127.0.0.1:9000; port 9000 filtered dari luar	DONE
B3	**Surface: Banner Web**	Header HTTP mengekspos versi spesifik Server: nginx/1.18.0	Direktif server_tokens off; header hanya menampilkan Server: nginx	DONE
C1	**Data: Validasi & ACL**	Kelembapan 150% diterima (HTTP 200) & publish MQTT anonim	Nilai di luar batas ditolak (HTTP 400); MQTT wajib auth & ACL	DONE
C2	**Data: File Kredensial**	Berkas .env mode 644 (terbaca user lain) & token literal di app.py	Izin berkas 600 (smartcow), env var, & rotasi token openssl	DONE
C3	**Data: Log & Backup**	Belum ada log akses khusus aplikasi maupun skrip backup lokal	Log aktif (auth=REDACTED) & uji restore smartcow-backup sukses	DONE



Sebelum: Login Sandi sec_admin Berhasil



Sesudah: Sandi Ditolak (Permission denied)



Sesudah: Injeksi RH 150% Ditolak (HTTP 400)

Rencana & Eksekusi Serangan Red Team Fase 2 (RT-01 s.d. RT-04)

Empat skenario pengujian ofensif terarah dari tiga kategori berbeda sesuai ketentuan Bagian IX Panduan PBL

Parameter Pengujian & Baseline Permukaan Serangan Awal (Fase 1)

Source IP: `192.168.12.100 (ATTACKER-KEL12-B)` -> **Target IP:** `192.168.12.5 (SRV-IOT-KEL12-B)` | `Ping 0% loss (RTT 1,202 ms)`

Temuan Nmap Awal (Sebelum Hardening): Port 22/tcp (OpenSSH 8.4), 80/tcp (nginx 1.18.0), 1883/tcp (MQTT), dan 9000/tcp (REST API 0.0.0.0) terbuka.

RT-01: Reconnaissance & Banner Grab

```
nmap -sS -sV -O -p 22,80,1883,9000
192.168.12.5
curl -I http://192.168.12.5/
```

Memetakan port TCP terbuka, mengidentifikasi rilis versi web server Nginx pada header HTTP, dan memeriksa eksposur langsung port internal 9000.

RT-02: SSH Brute-Force & Banjir Sesi

```
python3 ssh_try.py 192.168.12.5 root
sec_admin
for i in {1..8}; do ssh sec_admin@.5 & done
```

Menguji ketahanan autentikasi SSH port 22 terhadap tebakan kata sandi berulang serta meluncurkan 8 sesi paralel serentak untuk menguji rate limit.

RT-03: Injeksi REST & Publish MQTT Liar

```
mqtt_pub.py .5 1883 cow-sprinkler-01/control
'{"manualSsr":"on"}'
curl -X PUT ... -d '{"humidity":150}'
```

Mempublikasikan perintah penyalaan relay pompa tanpa kredensial ke broker MQTT serta menyuntikkan nilai kelembapan tidak logis (150%) ke REST API.

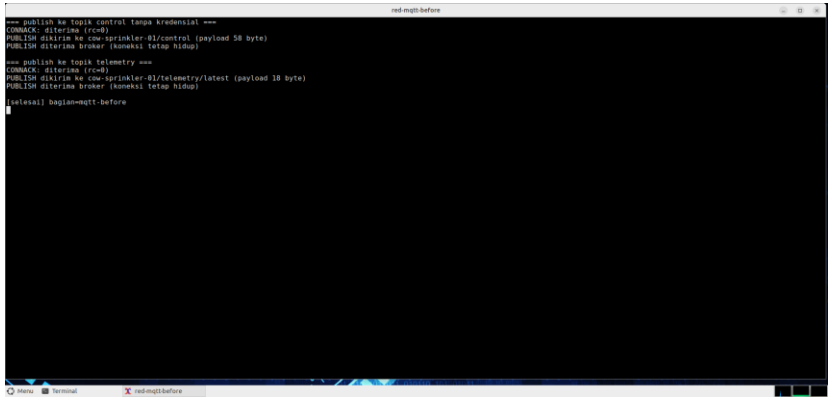
RT-04: MQTT Control Replay Attack

```
Penyadapan paket kendali pompa sah (.pcap)
Pengiriman ulang (replay) ke :1883 saat idle
```

Merekam paket kontrol pompa yang sah lalu mengirimkannya kembali di luar jadwal penyiraman untuk menguji validasi stempel waktu (timestamp) dan log.



Bukti RT-01: Pemindaian Nmap & Banner Sebelum Hardening



Bukti RT-03: Publish MQTT Tanpa Kredensial ke Topik Control

Evaluasi Purple Team Loop, Deteksi Sguil & Kendala Lab

Verifikasi siklus tertutup 5 tahap (Serang -> Deteksi -> Analisis -> Respons -> Verifikasi) dan korelasi alert IDS Security Onion

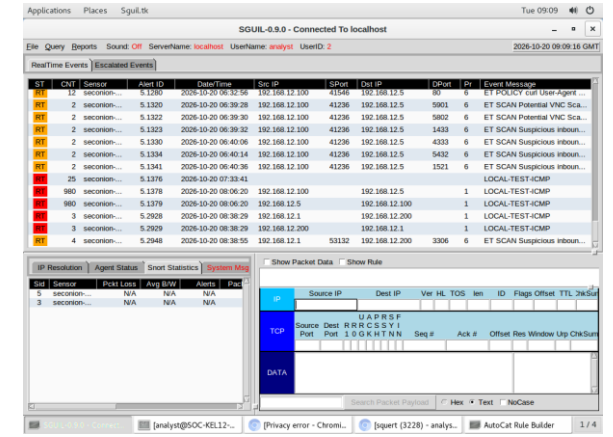
Tahap Siklus	RT-01 (Reconnaissance)	RT-02 (SSH Brute-Force)	RT-03 & RT-04 (MQTT & REST)
1. Serang (Awal)	Port 22, 80, 1883, 9000 terbuka; versi nginx/1.18.0 terlihat	Login sec_admin dengan kata sandi sederhana berhasil masuk	Publish anonim ke topik control & suntik RH 150% diterima (200)
2. Deteksi IDS	Sguil: ET SCAN Nmap Scripting Engine & Possible Nmap UA (:80)	Sguil: ET SCAN Potential SSH Scan (:22) & auth log verbose	Sguil: ET POLICY curl User-Agent (:80) & catatan broker.log
3 & 4. Respons	Bind API ke 127.0.0.1:9000 (B2) & set server_tokens off (B3)	Kunci Ed25519, PasswordAuth no (A2), & hashlimit 3/s (A3)	Aktifkan validasi rentang suhu/RH, wajib auth & ACL topik (C1-C2)
5. Verifikasi	Port 9000 filtered dari luar; header hanya Server: nginx	Sandi ditolak (Permission denied publickey); banjir sesi di-reset	Publish anonim ditolak (CONNACK 5); RH 150% ditolak (HTTP 400)

Kendala Operasional Laboratorium, Evaluasi False Positive & Solusi Tim

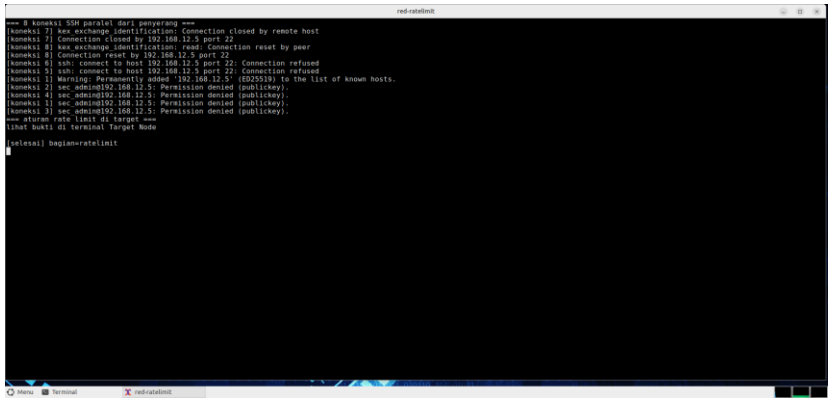
1. Sensor Sguil Awalnya Kosong (Minggu 5): tcpdump menangkap paket tetapi tabel RealTime Events kosong karena IDS_ENGINE_ENABLED=no dan NIC virtual belum disetel ke Promiscuous Allow. Solusi: Mengaktifkan kedua opsi dan merestart nsm_sensor_ps-start.

2. Isolasi Lab Tanpa Internet & Persistensi Firewall: Paket eksternal tidak bisa diunduh dan aturan iptables sempat tereset saat reboot. Solusi: Membangun modul Python 3.9 mandiri serta menyimpan aturan ke /etc/iptables/iptables.rules via systemd iptables.service.

3. Temuan False Positive Administratif: Koneksi SSH sah dari Host Laptop (192.168.12.1) ke Target sempat memicu alert ET SCAN Potential SSH Scan pada 06:27 GMT; dijadwalkan untuk tuning whitelist signature Snort pada Fase 2.



Bukti Deteksi Sguil (06:30-06:47 GMT / 13:30-13:47 WIB: Nmap, cURL, SSH)



Bukti Tahap 5: 8 Koneksi SSH Paralel Diredam Firewall (Connection reset)

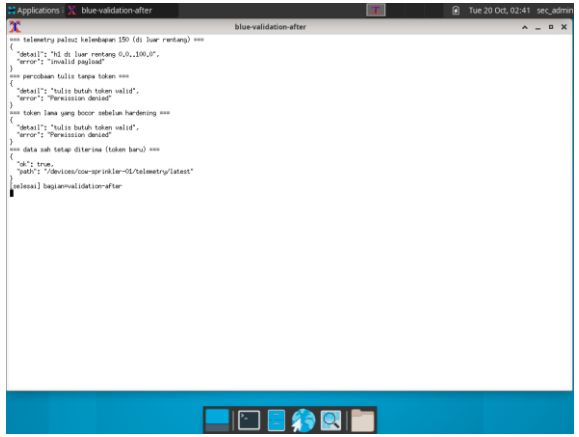
Rekomendasi Sistem Produksi & Catatan Pengumpulan GitHub

08 | PENUTUP & ARTIFAK

Tindak lanjut pengamanan untuk perangkat fisik/cloud SmartCow asli serta daftar periksa kelengkapan repositori Minggu ke-9

Rekomendasi Mitigasi untuk Sistem Produksi SmartCow (ESP32 & Firebase)

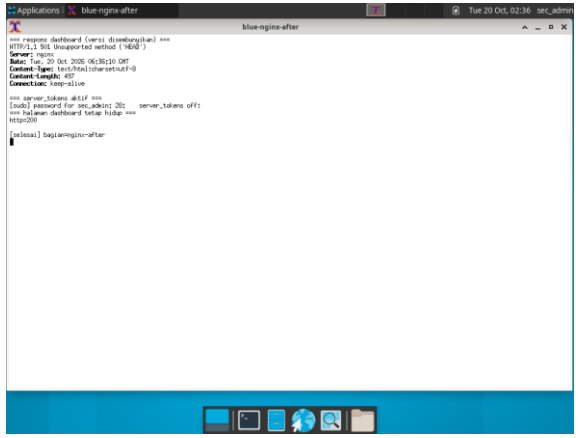
1. Cabut & Rotasi Database Secret: Hapus parameter ?auth= statis dari esp32/src/main.cpp dan ganti dengan autentikasi token berbatas waktu serta aturan peran /access/<uid> di Firebase RTDB.
2. Aktifkan Validasi Sertifikat TLS: Hapus pemanggilan client.setInsecure() pada firmware ESP32 dan sematkan sertifikat Root CA Google Trust Services untuk mencegah penyadapan MitM.
3. Enkripsi Kanal Nirkabel ESP-NOW: Terapkan Primary Master Key (PMK) dan Local Master Key (LMK) AES-128 pada transmisi 2,4 GHz antar-mikrokontroler ESP32 di kandang.
4. Validasi Rentang Server & Otorisasi MQTT: Terapkan aturan validasi rentang suhu/kelembapan di sisi database produksi serta gunakan MQTTS (port 8883) ber-ACL topik per perangkat.



Bukti Kontrol C1: Penolakan Kelembapan 150% & Token Lama (blue-validation-after)

Kepatuhan Struktur Folder GitHub & Catatan Pengumpulan Minggu ke-9

1. Pertahankan Berkas Minggu ke-4: Berkas docs/design/topology.png dan docs/design/ip_plan.md tetap tersimpan utuh tanpa dihapus atau ditimpa (mematuhi Bagian XI Panduan PBL).
2. Kelengkapan Dokumentasi Fase 1 -> 2: Berkas LOGBOOK.md, tech_stack_declaration.md, hardening_checklist.md (+28 bukti), attack_plan.md (+14 bukti), dan purple-team-log.md telah lengkap.
3. Instruksi Wajib Unggah Slide PDF Sebelum Sesi: Pastikan berkas presentasi format PDF (bukan .pptx) telah di-commit dan di-push ke path docs/presentation-minggu9/slides.pdf pada repositori github.com/SwipeLz/TEK1314-2026-Kel-12-Kelas-B sebelum sesi praktikum dimulai.



Bukti Kontrol B3: Penyembunyian Versi Header Server: nginx (blue-nginx-after)